

Разбор APK: BraveBuilder (Hetakira)

Package: com.vrx.farming.tractor.simulator.game • versionName 0.41 (versionCode 41) •
папка url-batch/BraveBuilder-Hetakira

SDK / стек

Параметр	Значение
Название приложения	Bcllc App (label в APK, @string/app_name); в Google Play карточка называется BraveBuilder
Android Gradle Plugin	8.10.0
minSdk	25
targetSdk	36
Kotlin	да, 1.6.21
Web View	да
Custom Tabs	да
Рекламные сети	нет
Аналитика	нет
Permissions	android.permission.INTERNET, android.permission.ACCESS_NETWORK_STATE
Libraries	Unity 6000.3.8f1 (IL2CPP): libil2cpp.so, libunity.so, lib_burst_generated.so, libc++_shared.so, libswappywrapper.so; UniWebView 4 (com.onevc.at.uniwebview) + UniWebView-CSharp.dll; androidx.browser 1.2.0; androidx.core 1.1.0; androidx.lifecycle-runtime 2.0.0; androidx.interpolator 1.0.0; androidx.versionedparcelable 1.1.0; androidx.collection; androidx.concurrent.futures; Kotlin stdlib 1.6.21; com.google.android.gamesdk (Swappy); com.google.common (Guava ListenableFuture); bitter.jnibridge; org.fmod; org.jetbrains.annotations; com.unity3d.player; DOTween, DOTweenPro, DemiLib; Cinemachine; Unity.TextMeshPro; Unity.Timeline; Unity.InputSystem; Unity.Burst, Unity.Collections, Unity.Mathematics; Unity.VisualScripting; Unity.AI.Navigation; Unity.Animation.Rigging; Unity.RenderPipelines.Core; Realistic Car Controller (RCC); System.IO.Hashing; System.Runtime.CompilerServices.Unsafe
Подозрительные домены	roving-futility.com, hetakira-7c48792c.surge.sh, bonecrackergames.com
SharedPreferences	сохраняет имя и возраст игрока, выбранный транспорт, монеты, прогресс уровней, настройки звука и музыки, настройки машины; результат проверки на сервере не сохраняет
Есть ли клоака	да
Подозрительные слова	aHR0cHM6Ly8= («https://»), cm92aW5nLQ== («roving-»), ZnV0aWxpdA== («futilit»), eS5jb20= («y.com»), cGxheQ== («play»), LmdvbW== («.goo»), Z2xlLg== («gle.»), Y29t («com»), DecodeTargetUrl, DecodePlayStoreUrl, RetrieveEndpoint, AnalyzeResponse, VerifyConnectivity, bypassContent, cachedEndpoint, retrievedEndpoint, QueryingRemote, EvaluatingResponse, RenderingContent, RestoringConnection, LaunchWebViewFragments, Fragment_01_InitializePhysics, Fragment_02_SyncNetwork, Fragment_03_MixAudio, Fragment_04_CalculateInventory, Fragment_05_UpdateBodies, Fragment_06_Finalize, HandleWebViewError, StopLoad

Проверка подозрительных доменов

Проверка домена: hetakira-7c48792c.surge.sh

Формат как на VirusTotal → Security vendors' analysis, в конце три доп. пункта.

Параметр / движок	Значение / вердикт
Домен	hetakira-7c48792c.surge.sh
VirusTotal URL	https://www.virustotal.com/gui/domain/hetakira-7c48792c.surge.sh
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean
ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean
AlienVault	Clean
Antiy-AVL	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
ChainPatrol	Clean
CINS Army	Clean
CRDF	Clean
CTX AI	Clean
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean
Juniper Networks	Clean
Kaspersky	Clean
LevelBlue	Clean
Lionic	Clean
Malwared	Clean
MalwarePatrol	Clean
OpenPhish	Clean
Phishing Database	Clean
Phishtank	Clean

Параметр / движок	Значение / вердикт
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Yandex Safebrowsing	Clean
ZeroCERT	Clean
0xSI_f33d	Unrated
alphaMountain.ai	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
Bkav	Unrated
Chong Lua Dao	Unrated
Cluster25	Unrated
CMC Threat Intelligence	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
Cyan	Unrated
DNS8	Unrated
Ermes	Unrated
Fortra	Unrated
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
Lumu	Unrated
MalwareURL	Unrated

Параметр / движок	Значение / вердикт
Mimecast	Unrated
Netcraft	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
URLQuery	Unrated
VIPRE	Unrated
Xcitium Verdict Cloud	Unrated
ZeroFox	Unrated
Куда редиректит	нет (без редиректа)
Что выводит (кратко)	title: page not found. page not found page not found powered by surge.sh
Где припаркован	регистратор: Porkbun LLC

Проверка домена: bonecrackergames.com

Формат как на VirusTotal → Security vendors' analysis, в конце три доп. пункта.

Параметр / движок	Значение / вердикт
Домен	bonecrackergames.com
VirusTotal URL	https://www.virustotal.com/gui/domain/bonecrackergames.com
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean
ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean
AlienVault	Clean
alphaMountain.ai	Clean
Antiy-AVL	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
Chong Lua Dao	Clean
CINS Army	Clean
CMC Threat Intelligence	Clean
CRDF	Clean
CTX AI	Clean

Параметр / движок	Значение / вердикт
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean
DNS8	Clean
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean
Juniper Networks	Clean
Kaspersky	Clean
LevelBlue	Clean
Lionic	Clean
Malwared	Clean
MalwarePatrol	Clean
OpenPhish	Clean
Phishing Database	Clean
Phishtank	Clean
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Xcitium Verdict Cloud	Clean

Параметр / движок	Значение / вердикт
Yandex Safebrowsing	Clean
ZeroCERT	Clean
0xSI_f33d	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
Bkav	Unrated
ChainPatrol	Unrated
Cluster25	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
Cyan	Unrated
Ermes	Unrated
Fortra	Unrated
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
Lumu	Unrated
MalwareURL	Unrated
Mimecast	Unrated
Netcraft	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
URLQuery	Unrated
VIPRE	Unrated
ZeroFox	Unrated
Куда редиректит	https://www.bonecrackergames.com/
Что выводит (кратко)	title: Realistic Vehicle Physics for Unity BoneCracker Games. Realistic Vehicle Physics for Unity BoneCracker Games Skip to content Menu Home Contact Search for: × BoneCracker Games Unity Assets Realistic Vehicle Behaviors Best physics based vehicle controller scripts by BoneCracker Games for Unity Engine. Menu Home Vehicle Control
Где припаркован	регистратор/whois связан с парковкой: godaddy

Какие данные собираются

- наличие подключения к интернету

Как собираются

Приложение берёт эти сведения само, в первый же миг после запуска, без единого вопроса к человеку. Экран заставки (класс `Splash`) сразу выставляет себе шаг «проверяю сеть», и уже на первом кадре работы вызывается проверка `GameManager.VerifyConnectivity`, которая спрашивает у системы Android, есть ли вообще выход в интернет.

Больше приложение ни о чём телефон не спрашивает. Отдельно просмотрены весь код запуска и все сетевые места: язык, страну, модель телефона, версию Android, рекламный номер устройства, `android_id`, имя оператора, часовой пояс и размер экрана приложение для этой проверки не читает и в запрос не кладёт. В файле приложения даже нет собранного кода для получения рекламного номера — значит, его никто не запрашивает.

Разрешений у приложения всего два — выход в интернет и просмотр состояния сети. Никакого окна с согласием, никакой галочки и никакого предупреждения человек не видит: он смотрит на заставку с полоской загрузки, а в это время приложение уже молча выходит в интернет.

Прочие сведения о человеке приложение всё же хранит, но не для этой проверки и не отправляет их никуда: имя и возраст игрока, монеты, прогресс уровней и настройки звука лежат в собственном файле настроек приложения на самом телефоне.

Куда отправляются

Тихий запрос уходит на один адрес — <https://roving-futility.com>. В файле приложения этого адреса нет в читаемом виде: он склеен из четырёх закодированных кусочков («aHR0сHM6Ly8=», «cm92aW5nLQ==», «ZnV0aWxpdA==», «eS5jb20=»), которые раскодируются и соединяются прямо во время работы (метод `GameManager.DecodeTargetUrl`). Поэтому обычный поиск по строкам этот адрес не находит — это сделано, чтобы адрес не бросался в глаза при проверке.

Запросов ровно один и запасных адресов для проверки нет: во всём приложении есть единственный сетевой вызов собственного кода (`GameManager.RetrieveEndpoint`), и он идёт именно туда. Ответа приложение ждёт не больше 15 секунд.

Уходит это совсем незаметно: без экрана, без звука, во время заставки. Пока запрос летит, на экране крутится обычная полоска загрузки, а рядом ещё и запускается «анимация ходьбы» (строка «walk») — то есть внешне всё выглядит как подготовка игры.

Адрес, который приходит в ответ, приложение кладёт себе в память (поля `retrievedEndpoint` и `cachedEndpoint`) и на диск не записывает. Если интернет пропадёт, приложение каждые три секунды проверяет связь и, как только она вернётся, снова открывает тот же самый запомненный адрес.

Кроме этого в приложении есть три обычных ссылки, которые открываются только по нажатию кнопок в меню: страница приложения в Google Play, страница разработчика Hetakira в Google Play и страница политики конфиденциальности <https://hetakira-7c48792c.surge.sh/com.vrx.farming.tractor.simulator.game/50e2bb39>. Сами по себе они ничего не отправляют.

Как фильтруются пользователи

Самое важное здесь: решение «кому оффер, а кому обычное приложение» приложение не принимает. Оно вообще не сообщает серверу ни одного признака о телефоне — запрос уходит «пустым», без каких-либо добавленных полей, без дописанных к адресу параметров и без своих служебных строк.

Значит, сортировать посетителей сервер может только по тому, что видно у любого обращения в интернет само собой: по сетевому адресу телефона (из него понятны страна и оператор) и по служебной подписи программы, которая делает запрос. Никаких списков стран, языков или «плохих» устройств внутри приложения нет — просмотрены все ветки кода.

Единственное правило, которое приложение выполняет само, — это проверка связи. Если интернета нет совсем, никакой проверки не будет и человеку сразу останется обычное приложение.

Второе и главное правило — куда именно сервер отправит запрос дальше. Приложение смотрит на конечный адрес и ищет в нём «play.google.com». Этот адрес тоже скрыт по кускам («cGxheQ==», «Lmdvbw==», «Z2xlLg==», «Y29t») и собирается в момент работы (метод `GameManager.DecodePlayStoreUrl`).

Получается честная картина: приложение — это только исполнитель, а всю сортировку делает сервер на стороне. Хозяин схемы может в любой момент менять правила у себя, не выпуская обновление приложения, и по одному файлу приложения нельзя сказать, кого именно он пускает на оффер.

Что возвращается

Ответ читается очень скупо, и это тоже показатель: сам текст страницы приложение не разбирает вообще. Никаких полей вида «url», «offer» или «status» из ответа не берётся — в коде вообще нет чтения содержимого ответа.

Приложение смотрит всего на три вещи. Во-первых, что запрос прошёл без ошибки. Во-вторых, что сервер ответил кодом «200», то есть «всё в порядке». В-третьих — и это ключ ко всей схеме — на какой адрес запрос в итоге привёл после всех перебросов сервера.

Если в этом конечном адресе есть «play.google.com», приложение считает ответ «чистым»: сервер попросту отфутболил посетителя на страницу магазина и никакой цели для него не приготовил.

Если конечный адрес любой другой — то есть сервер оставил посетителя у себя или перевёл на третий сайт, — этот адрес и становится целевым. Именно он дальше открывается человеку.

Если же связи не было, ответ пришёл с ошибкой, код оказался не «200» или ждать пришлось дольше 15 секунд, запомненный адрес остаётся пустым, и это тоже считается «чистым» вариантом.

Как показывается оффер или белая версия

Когда адрес получен, приложение открывает его не рекламным блоком поверх игры, а встроенным окном сайта внутри самого приложения (UniWebView) — фактически это браузер без адресной строки и без кнопок, растянутый на весь экран.

Показ разбит на шесть шагов, которые запускаются друг за другом с задержками в сотые доли секунды, и названы они как обычные игровые процедуры:

«Fragment_01_InitializePhysics», «Fragment_02_SyncNetwork», «Fragment_03_MixAudio»,

«Fragment_04_CalculateInventory», «Fragment_05_UpdateBodies», «Fragment_06_Finalize». По названиям кажется, что это физика, звук и инвентарь, а на деле шаги создают окно сайта, включают в нём выполнение скриптов и разрешают всплывающие окна, разрешают любой поворот экрана, растягивают окно на весь экран, загружают полученный адрес и показывают его.

Дальше приложение не даёт этому окну исчезнуть. Каждый кадр окно заново растягивается на всю площадь экрана, а встроенный обработчик закрытия вместо закрытия просто перезагружает страницу — то есть привычная кнопка «назад» возвращает человека на ту же страницу. Если интернет пропал, окно прячется, и как только связь появится, тот же адрес откроется снова.

Что именно на этой странице, по файлу приложения увидеть нельзя: адрес выдаёт сервер, и в приложении он не записан. Видно только то, что страница показывается вместо приложения и на весь экран, а не как реклама внутри игры.

Если же ответ оказался «чистым», ничего внешнего не открывается: приложение загружает свою обычную сцену, и человеку остаётся обычное приложение.